

Chapitre 2: Malwares & Supercherie

Présenté par : Dr. Rabah RAHAL
M1 RSI 2024-2025

Plan-Chapitre 2: Malwares & Supercherie

1. Introduction, Historique
2. Types des Malwares et leurs objectifs
3. Vecteur d'infection
4. Analyse des Malwares
5. Techniques d'Obfuscation et d'Évasion
6. Protection contre les malwares
7. Éthique et Légalité

1. Introduction

- Qu'est-ce qu'un malware ?
- Un malware, ou logiciel malveillant, est un programme conçu pour **infiltrer**, **endommager** ou **obtenir un accès non autorisé** à un système informatique, un réseau ou un appareil. Les malwares peuvent se présenter sous différentes formes.

Historique

1. Le Creeper Program

- Créé en 1971, est considéré comme le premier virus informatique. Il se propageait via ARPANET et affichait le message "I'm the creeper: catch me if you can."
- Creeper ne se copiait pas, mais se déplaçait d'un ordinateur à un autre en s'effaçant du système précédent après chaque migration.

● Questions:

- ARPANET vs Internet ?
- Est-il vraiment malicieux ?
- Facile à créer ?

2. Reaper Program

- Reaper a été développé en 1971 par Ray Tomlinson. Son but était de supprimer Creeper des systèmes infectés.
- Questions:
 - Si ce malware lutte contre les malwares, on peut le considérer comme quoi ?

3. The Wabbit (Rabbit)

- Développé en 1974, son but était de créer des processus systèmes et de copier les fichiers systèmes jusqu'à la saturation de la machine.
- Questions :
 - Son comportement vous rappelle quel type d'attaque ?
 - Que pensez-vous de ce qu'il fait par rapport à Creeper ? Donc, qui est vraiment le premier malware ?

4. ILOVEYOU (années 2000) :

- Propagé principalement **par e-mail**, le message contenait un fichier joint nommé "**LOVE-LETTER-FOR-YOU.txt.vbs**".
- Une fois ouvert, le virus vole les mots de passe et envoie des copies de lui-même à tous les contacts de la victime.

5. Menaces actuelles (2020 et au-delà)

- **APT** (Advanced Persistent Threats)
- **Les botnets IoT** : Les objets connectés (caméras, routeurs) sont de plus en plus ciblés par des malwares pour former des réseaux de botnets.

2. Types de malwares et leurs objectifs

Virus:

- Code exécutable malveillant **attaché** à un autre fichier exécutable légitime.
- **Nécessite l'intervention** de l'utilisateur pour s'exécuter.
- S'installe en première line de code dans un fichier exécutable.
- Cherche d'autres exécutables pour les infecter.
- Mode de diffusion: supports amovibles, téléchargements, pièces jointes
- Caractéristique: mutation.

Worms (vers)

- Code malveillant qui exploite une vulnérabilité dans le system (machine ou réseau)
- Contrairement au virus le ver ne s'attache pas à un programme , et n'a pas besoin de l'intervention de l'utilisateur pour s'exécuter,
- Se propage rapidement à travers le reseau.
- Techniquement, c'est un Virus autonome.

Spyware & downloader

- **Spyware:** chargé de recueillir des informations sur l'utilisateur de l'ordinateur sur lequel il est installé afin de les envoyer à celui qui le diffuse.
- logiciel qui permet à un cybercriminel d'obtenir des informations sur les activités informatiques d'un utilisateur
 - suivi des activités, collecte de frappes sur clavier (**keylogger**), capture des données.
 - modifie souvent les paramètres de sécurité
- **Downloader:**
- téléchargé, via des pièces jointes
- communiquent avec le serveur de commande et télécharge des malwares additionnels.

Trojan (Cheval de Troie)

- Effectue des opérations malveillantes **sous le couvert** d'une opération souhaitée
- Exploite les privilèges de l'utilisateur qui l'exécute
- **Ne s'auto-répliquent pas.**

Ransomware

- Chiffre et bloque les fichiers de la victime et demande une rançon en échange d'une clé permettant de les déchiffrer.
- S'infiltrer sous la forme d'un ver informatique, à travers un fichier téléchargé ou reçu par email et chiffre les données et fichiers de la victime.
- La finalité est d'extorquer une somme d'argent à payer le plus souvent par monnaie virtuelle pour éviter toute trace.

3. Méthodes de propagation

(Vecteur d'infection)

Question : À votre avis, **comment** un malware parvient-il à **infecter** une machine cible ?

Social Engineering (SEToolkit)

3.1. Phishing (hameçonnage)

- Phishing est le type **le plus répandu** d'ingénierie sociale, reste le vecteur d'attaque numéro 1 pour toutes sortes de malwares.
- Les attaquants ciblent particulièrement les **emails** (en PJ) ou bien a travers un **lien malicieux**.
- -- **s'il est ouvert** -- l'attaquant a atteint une cible précieuse qui fait partie du réseau de l'entreprise visée.

Étapes pour Créer un E-mail de Phishing

- A votre avis, quel sont les étapes nécessaires pour créer un email de phishing ?

Étapes pour Créer un E-mail de Phishing

1. Rédiger le contenu du message : Écris un message qui pourrait **convaincre l'utilisateur** de cliquer sur le lien ou d'ouvrir la pièce jointe.
2. Ajouter un lien directement téléchargeable.
3. Ou bien: Ajouter le malware En PJ.

3.1. Phishing : Exemple 1:

Quels outils pouvez-vous utiliser pour créer un lien téléchargeable ?

3.1. Phishing : Exemple 1:

Google Drive:

1. Importe le fichier .exe
2. Modifié les options de partage
3. Récupéré le lien
4. Modifie le lien pour le rendre directement téléchargeable

3.1. Phishing : Exemple 1:

1. Récupéré l'ID du fichier:

[https://drive.google.com/file/d/1yCDJ6T-3T7Id5-4T1ZN6-5zYVLU1KnrC/view?usp=drive link](https://drive.google.com/file/d/1yCDJ6T-3T7Id5-4T1ZN6-5zYVLU1KnrC/view?usp=drive_link)

2. Le mettre de une structure dédié au téléchargement direct:

<https://drive.google.com/uc?export=download&id=1yCDJ6T-3T7Id5-4T1ZN6-5zYVLU1KnrC>

Problème: Detection, blocage !

-> .Zip

-> d'autres outils (Dropbox)

3.1. Phishing : Exemple 2:

Drope box:

https://www.dropbox.com/scl/fi/u88oe6nl43jnl6uilwmbx/k_Test.exe?rlkey=g8j2ccrvc36hy6agmaemzwkuu&st=5ibx3m03&dl=0 Remplace le dernier 0, par un 1

dl=1 force le téléchargement, mais cela ouvre souvent une fenêtre de dialogue pour choisir l'emplacement de sauvegarder. Cela fait partie du comportement standard des navigateurs pour les fichiers exécutables.

3.2. Réseaux sociaux et Siteweb malveillants:

- Réseaux sociaux : En plus des emails, les cybercriminels peuvent utiliser d'autres plateformes pour diffuser les liens des malwares.
- Sites Web malveillants : Les malwares peuvent se propager via des sites malveillants ou ceux infectés par des publicités nuisibles.

3.3. Exploitation des vulnérabilités :

- Certains malwares se propagent en exploitant des vulnérabilités dans les systèmes ciblés.
- **Mirai** par exemple, utilisent des techniques de scan (similaires a Nmap) pour rechercher d'autres dispositifs vulnérables sur Internet afin de les infecter.
 - Mais comment ça se fait, le scanning ?

3.3. Exemple d'Exploitation des vulnérabilités :

- Identification des @IP de tout les appareils sur le même réseau que la machine infecté?

`sudo nmap -O 192.168.1.0/24`

- Cherchez des vulnérabilites

`sudo nmap --script vuln 192.168.1.0/24`

- Quel est la prochaine étapes ?

- Faites-attention !

3.4. Supports amovibles :

- Les clés USB et disques durs externes infectés sont des tactiques courantes pour diffuser des logiciels malveillants par ingénierie sociale. Lorsqu'un utilisateur branche un support infecté, le malware peut s'exécuter via Autorun (si activé) ou être caché dans un fichier infecté avec un nom attrayant.

3.Méthodes de propagation (*Vecteur d'infection*)

1. Ingénierie sociale (Phishing)
2. Réseaux sociaux et sites
3. Exploitation de vulnérabilités
4. Supports amovibles

4. Analyse des Malwares

- Les techniques d'analyse se divisent principalement en deux catégories : **statique** et **dynamique**.
 1. L'analyse statique consiste à **examiner le code** du malware **sans l'exécuter**.
 2. L'analyse dynamique implique l'**exécution** du malware **dans un environnement contrôlé** pour **observer** son comportement.

4.1. L'analyse statique

4.1. L'analyse statique

- 1. Extraction des chaînes :
- Recherche de chaînes de caractères dans le fichier qui peuvent donner des indications sur son fonctionnement ou ses intentions (ex : URL, noms de fichiers). (Outil: Strings)
- 2. Analyse de la signature :
- Comparaison du de la signature du code malveillant avec une base de données de signatures de malwares connus. Les antivirus utilisent souvent cette méthode (**hash fonction**).

4.1. L'analyse statique

- 3. Désassemblage :

Utilisation d'outils comme **IDA Pro** ou **Ghidra** pour convertir le code machine en un langage lisible, permettant d'examiner les instructions et la logique.

4. Inspection des métadonnées : l'auteur, les certificats, et les dépendances.

4.2. L'analyse dynamique

4.2. L'analyse dynamique

- 1. Analyse du réseau :

Pourquoi faire ? Et comment (outil)

Observation des connexions réseau établies par le malware, permettant de détecter des communications avec des serveurs de commande et de contrôle.

4.2. L'analyse dynamique

- 2. Traçage des processus:

C'est quoi un processus et pourquoi en garde leurs traces pour l'analyse?

Utilisation d'outils comme **Process Monitor (Procmon)** pour suivre l'activité des processus en temps réel.

4.2. L'analyse dynamique

- 3. Enregistrement de la mémoire et les appels système:

Pourquoi faire a votre avis? Le suivi des processus n'est pas suffisant ?

Capture de l'état de la mémoire pendant l'exécution du malware pour identifier les données manipulées ou les code injections.

4.2. L'analyse dynamique

- P.S: Vous devez assurer un environnement isolé avant d'exécuter le malware et faire des records sur ces activités.
- Quel outils pouvez-vous utiliser ?

4.2. L'analyse dynamique

- 4. Sandboxing :
- Exécution du malware dans un environnement isolé pour observer ses actions (modifications de fichiers, connexions réseau, etc.) sans risquer d'endommager le système hôte.

4. Analyse des Malwares

- A votre avis, quel est la meilleur méthode d'analyse ?
- Détection basée sur l'IA ?

5. Techniques d'Obfuscation et d'Évasion

- Obfuscation de code

- Crypteur :

Le code est chiffré puis déchiffré au moment de l'exécution, rendant l'analyse statique difficile pour les antivirus.

- Packers :

Utiliser des outils appelés "packers" pour compresser le malware, qui est ensuite décompressé en mémoire, masquant ainsi sa signature.

5. Techniques d'Obfuscation et d'Évasion

- **Polymorphisme :**

Modifier le code source du malware à chaque infection, en changeant la structure sans en modifier la fonctionnalité. Cela rend les signatures statiques inefficaces.

- **Métamorphisme :**

Modifier le code de manière plus profonde en changeant la logique et la structure, créant ainsi des variantes uniques à chaque fois. Cela complique considérablement la détection.

5. Techniques d'Obfuscation et d'Évasion

- Évasion des solutions de sécurité
- Évasion de l'analyse dynamique :

Certaines techniques de timing, comme l'attente d'une durée prolongée avant de s'exécuter, ou des conditions spécifiques (connexion Internet, actions de l'utilisateur), permettent d'éviter d'être analysé par les outils de sécurité.

5. Techniques d'Obfuscation et d'Évasion

- Évasion des solutions de sécurité

- Anti-debugging :

Techniques visant à détecter et à interrompre les outils de débogage pour éviter l'analyse approfondie (par exemple, vérifier si des processus de débogage sont en cours).

- Anti-sandboxing :

Les malwares tentent de détecter s'ils sont exécutés dans un environnement de sandboxing (bac à sable). des indicateurs tels que des **noms de processus**.

6. Protection

- Sensibilisation
- Logiciels à jour
- Antivirus
- Pare-feu hôte
- Système de détection hôte
- Filtrer les e-mails, utiliser des filtres d'hôte/serveur

7. Éthique et Légalité